Планировщик отпусков

КОРПОРАТИВНЫЙ ГРАФИК ОТПУСКОВ И СОГЛАСОВАНИЙ

SBOM и лицензии

Состав компонентов для реестра отечественного ПО · версия 1.0.0

30 октября 2026

© Alexander Yurasov

Содержание

1 О документе 3

2 Состав и генерация 4

3 Классификация лицензий 5

4 Текущее состояние (v1.0.0) 6

5 Контроль в конвейере 7

6 Ответственность 8

7 Изменение классификатора 9

1 О документе

Документ описывает, как ведётся состав сторонних компонентов (SBOM) «Планировщика отпусков» и как проверяются их лицензии. Цель — **регистрация системы в реестре отечественного ПО** (постановление Правительства РФ № 1236): правообладатель подтверждает, что сторонние компоненты используются на условиях, не противоречащих требованиям реестра, и не обязывают раскрывать исходный код регистрируемого ПО.

АРТЕФАКТ	ЧТО ЭТО
`sbom/server.cdx.json`, `sbom/web.cdx.json`	SBOM в формате CycloneDX 1.5 (генерируется, в git не хранится)
`docs/sbom/licenses-report.md`	Отчёт по лицензиям (генерируется, хранится в git)
`scripts/license-report.mjs`	Классификатор лицензий и генератор отчёта

2 Состав и генерация

АРТЕФАКТ	ПАКЕТ	КОМАНДА
`sbom/server.cdx.json`	`server/` — API на NestJS	`cd server && npm run sbom`
`sbom/web.cdx.json`	`web/` — клиент на Vue	`cd web && npm run sbom`
`docs/sbom/licenses-report.md`	оба пакета	`node scripts/license-report.mjs`

Всё вместе — `make sbom`. SBOM строится по `package-lock.json` (`--package-lock-only`), поэтому состав детерминирован и воспроизводим (`--output-reproducible`); вложенные компоненты разворачиваются в плоский список (`--flatten-components`). Формат CycloneDX 1.5 читают инструменты Минцифры и коммерческие сканеры.

В SBOM входят зависимости, которые попадают в поставку и сборку. Инструменты документации (`tools/docs`) в поставку не входят и в отчёт не включаются; их лицензии разрешительные и зафиксированы в `docs/decisions.md`.

3 Классификация лицензий

КЛАСС	ПРИМЕРЫ	РИСК ДЛЯ РЕЕСТРА	ПОЛИТИКА
Разрешительные	MIT, MIT-0, Apache-2.0, BSD-2/3, ISC, 0BSD, BlueOak, CC0, Unlicense, Python-2.0, PSF-2.0, составные `OR` / `AND` из них	Низкий	Допускаются; авторство указывается в документации
Двойные с разрешительной альтернативой	`MIT OR GPL-3.0-or-later`	Низкий	Допускаются: используется разрешительная ветвь
Слабый copyleft	LGPL, MPL-2.0	Средний	Только с ревью технического лидера и записью в `docs/decisions.md`
Сильный copyleft	GPL-2.0/3.0, AGPL	Высокий	**Запрещены**
Не определена	Нет поля `license` и неизвестен текст	Высокий	Блокер слияния: установить по тексту LICENSE или отказаться от зависимости

4 Текущее состояние (v1.0.0)

ПОКАЗАТЕЛЬ	ЗНАЧЕНИЕ
Компонентов (уникальных `name@version`)	852 в двух пакетах
Различных лицензий	20
Copyleft и неопределённых	0
Вердикт	Препятствий для регистрации в реестре не выявлено

Три компонента (`buffers`, `busboy`, `streamsearch`) не заполняют поле `license` в манифесте; их лицензия MIT установлена по тексту LICENSE-файла и зафиксирована в таблице исключений скрипта (в отчёте помечены `*`). При обновлении их версий лицензия проверяется вручную.

В v0.4.0 добавлены `nodemailer` (MIT-0) и, через js-yaml 5.5, `argparse` (PSF-2.0): обе лицензии разрешительные и внесены в классификатор с обоснованием в `docs/decisions.md`. Транзитивные уязвимые версии `multer` и `js-yaml` заменены исправленными через `overrides` в `server/package.json`.

В v0.5.0 новых зависимостей нет, состав не изменился: метрики Prometheus — собственный реестр вместо `prom-client`, генератор нагрузки — на встроенном `fetch` вместо k6 (AGPL-3.0), реплика и архив WAL — штатные средства PostgreSQL.

В v1.0.0 новых зависимостей тоже нет: инструменты нагрузки, сборщик ресурсов, SMTP-приёмник и генератор уведомлений о лицензиях — без зависимостей, на встроенных модулях Node.js. Добавлены сведения для реестра: из SBOM строятся перечень компонентов `docs/sbom/sbom-components.csv` и уведомления «Сторонние компоненты и лицензии» (`node scripts/third-party-notices.mjs`). В поставку входят 344 компонента (сервер — 336, клиент — 8; остальные — инструменты сборки и тестирования), все под разрешительными лицензиями. Базовые образы контейнеров — `node:22-alpine`, `nginx:1.27-alpine`, `postgres:17-alpine` — поставляются как отдельные программы (агрегирование). Сборка образов не отправляет статистику установки (`SCARF_ANALYTICS=false`, `scarfSettings`), Prisma CLI не обращается к своему серверу (`CHECKPOINT_DISABLE=1`).

Полный перечень — `docs/sbom/licenses-report.md`; он перегенерируется автоматически и вручную не правится.

5 Контроль в конвейере

1. На каждый push и PR задание «SBOM и лицензии» в GitHub и Gitea генерирует SBOM и отчёт; задание падает при лицензии среднего или высокого риска либо неопределённой.
2. SBOM публикуется артефактом прогона — состав известен для каждого коммита.
3. PR с новой зависимостью содержит обновлённый `package-lock.json`, отчёт и запись в `docs/decisions.md` с обоснованием.
4. При выпуске версии итоги SBOM (число компонентов и вердикт) фиксируются в `docs/versions.md`.

6 Ответственность

РОЛЬ	ОТВЕТСТВЕННОСТЬ
Технический лидер	Владелец процесса; ревью новых зависимостей и изменений классификатора
CI	Генерация и проверка на каждый коммит
Юридическая служба	Интерпретация спорных лицензий по запросу с приложением отчёта

7 Изменение классификатора

Новая лицензия добавляется в таблицу `LICENSE_CLASS` скрипта `scripts/license-report.mjs` с обоснованием в `docs/decisions.md`. Изменение политики раздела «Классификация лицензий» — только через ревью технического лидера.